Amazon GuardDuty is a threat detection service that uses ML technology to continuously monitor customers' AWS accounts for malicious activity and unauthorized behavior. In the next section, we will fully discuss GuardDuty and see how it can be integrated and built into a security ecosystem for security hardening.

Case study – an AWS threat detection and incident handling ecosystem

After the introduction of Amazon logging and monitoring services in the last section, we will conduct a case study on an actual security incident and details on how it was handled, by introducing an **automatic threat detection and remediation system** that the author developed for an AWS customer.

CloudSpace is an Amazon enterprise customer that functions as a reseller of AWS services to end customers, with over 4,000 AWS accounts in total. During 2017-2018, CloudSpace experienced three cases of account compromise. Three accounts were compromised in the first attack in November 2017, and four more in the second attack in March 2018. The third incident occurred in August 2018, when another five accounts were compromised. These incidents led to about $200,000 in losses. Investigations thereafter revealed that no threat-detection services were enabled and the Amazon fraud detection team's customer notifications went to their company emails and voice mails manually and thus were not acted upon in a timely manner.

To defend against these attacks, we have developed an automated threat detection and remediation ecosystem. The architecture of the system is shown in *Figure 7.14*:

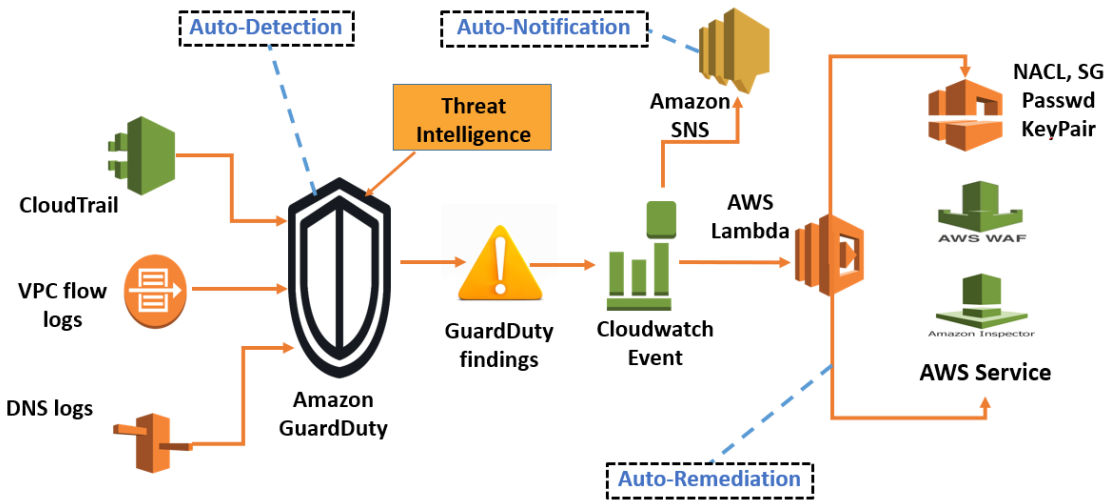


Figure 7.14 – Architecture of the threat detection and remediation ecosystem

The ecosystem has the following functions.

Automatic threat detection

Enabling Amazon GuardDuty is the first step for the ecosystem to work. As we discussed earlier, GuardDuty uses machine learning to monitor and generate the activity patterns of the AWS account, such as the normal and peak times and scope, and leverages threat intelligence to analyze and correlate data from various sources, such as AWS CloudTrail, Amazon VPC Flow Logs, and DNS logs, to detect and prioritize potential security threats. Once GuardDuty is enabled, it will continuously monitor the AWS accounts for malicious activity and unauthorized access automatically. GuardDuty can detect a variety of threats, including botnets, port scanning, cryptocurrency mining, and unauthorized API access. It can also provide users with detailed information about the nature of the threat, including the source IP address and the affected AWS resources.

Automatic notification

When GuardDuty detects a threat, it generates a finding in the GuardDuty console and creates a Cloudwatch event, which can be used to automatically notify the customer. In the ecosystem, GuardDuty integrates with **Simple Notification Service** (**SNS**) and some third-party tools, enables timely notifications about possible threats, and facilitates notifications to multiple parties, via Slack and its ticketing system.

Automatic remediation

In addition to notifications, CloudWatch events can trigger Lambda functions that serve as the basis for remediation. Depending on the attack, a customer can choose to automatically terminate a compromised instance if it is part of a non-critical development sandbox account, or to be notified only if the instance is part of a production workload. Following are some remediation actions we explored in the ecosystem:

- Blocking bad actor access with NACL and SG modifications
- Enabling MFA for accounts if not yet done
- Changing account user passwords
- Deleting and rotating account access keys (while being cautious about production accounts and ensuring applications are not using the keys before rotating them)
- Snapshotting compromised EC2 instances for forensic investigation
- Running Amazon Inspector assessments on compromised EC2 instances (or forensic instances launched based on snapshots)
- Terminating compromised EC2 instances (be cautious with production instances, termination is best suited for stateless applications that are deployed using Auto Scaling)
- Deleting all images (AMIs) created during the compromise
- Deleting all snapshots created during the compromise

The ecosystem was deployed successfully in the customer's environment. It guard-railed the customer against several successive attacks, and the customer loves the ecosystem and became one of the top 10 GuardDuty consumers in 2018.

Summary

In this chapter, we started with the Amazon cloud security model, then discussed IAM, which manages authentication, authorization, and auditing. We dived into AWS cloud infrastructure security, which protects cloud resources such as EC2, S3, and RDS, and data security, which is about data encryption and key management. We further explored the AWS data encryptions, cloud monitoring and logging services, and ended with a case study about an AWS automatic cloud threat detection and remediation ecosystem.

We have now concluded *Part 1* of the book: *Learning the Amazon Cloud*. In the next part, we will explore Google Cloud Platform.

Practice questions

Questions 1-10 are based on the AWS architecture shown in *Figure 7.15*. There is a cloud admin in company ABC, which has 10,000 EC2 instances in its AWS cloud. The diagram shows the three VPCs in the cloud admin account. All networks are configured correctly. The cloud admin created an EC2 role, R3, that can access the S3 bucket named `B3` in `us-east-1`. EC2-1 has a security group named `sg`. `Subnet1` has a network access control list named `nacl`:

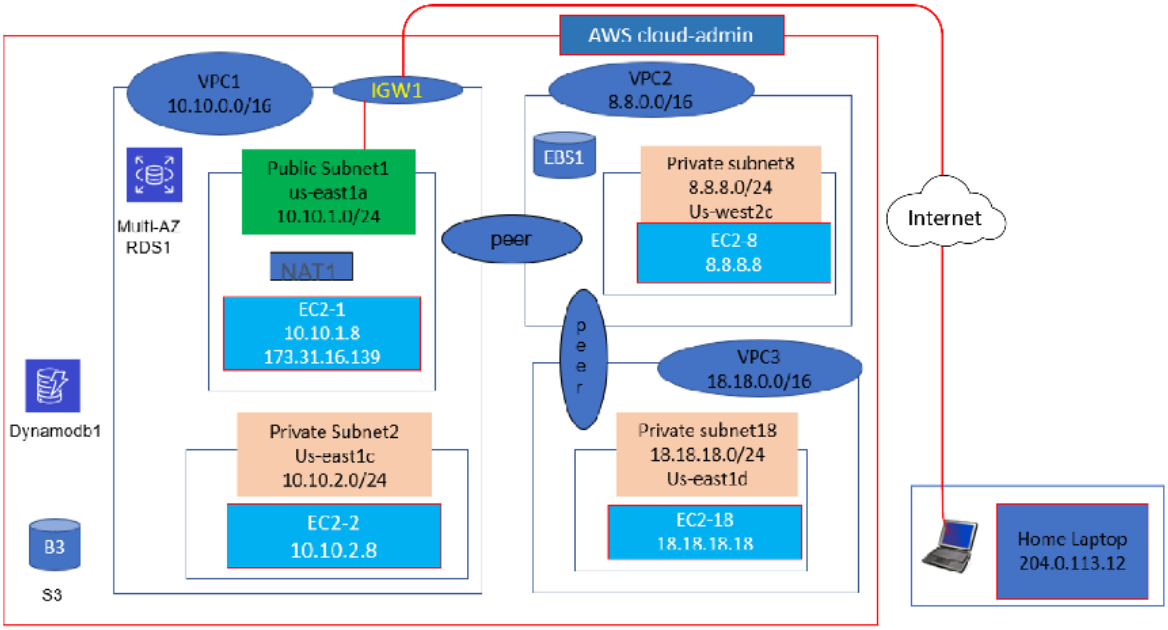


Figure 7.15 – AWS Networking Architecture

1. They are looking for a place to securely store a connection string to RDS1. What do you suggest?

    A. EBS

    B. Parameter store

    C. DynamoDB

    D. RDS

2. They couldn't ping EC2-1 from their home laptop, and he found the following in the AWS VPC flow log:

```
2 123456789010 eni-1235b8ca123456789 204.0.113.12 173.31.16.139
0 0 1 4 336 1432917027 1432917142 ACCEPT OK
```

```
2 123456789010 eni-1235b8ca123456789 173.31.16.139 204.0.113.12
0 0 1 4 336 1432917094 1432917142 REJECT OK
```

    What is the likely reason the "ping" did not work?

    A. NACL outbound rule blocked the traffic

    B. SG inbound rule blocked the traffic

    C. NACL inbound rule blocked the traffic

    D. SG outbound rule blocked the traffic

3. How can they block the contractors/developers from accessing the EC2-18 instance's metadata?

    A. Modify EC2-18's GuestOS route table

    B. Modify Subnet18's NACLs

    C. Modify EC2-18's SG

    D. Modify EC2-18's GuestOS `/etc/passwd` file

4. How can they set the correct date/time on all 10,000 EC2 instances?

    A. Use AWS Systems Manager

    B. Use AWS Security Center

    C. Use AWS Config

    D. Use AWS Inspector

5. No one in the company can access the Linux instance EC2-8. What can they do to log into it?

    A. Generate a new keypair and utilize EC2-8's user data to copy the public key to EC2-8

    B. Generate a new keypair and utilize EC2-8's metadata to copy the key to EC2-8

    C. Generate a new keypair and `scp` the public key to EC2-8 to `ssh` into it

    D. `ssh` into a third Linux instance, EC2-1, and break into EC2-8 from there

6. Which of the following is not true?

A. EC2-1 can ping EC2-8

B. EC2-8 can ping EC2-18

C. EC2-1 can ping EC2-18

D. EC2-2 can ping EC2-8

7. C2-18 needs to access the internet for patching. Which one of these options is true?

A. It can be done via IGW1

B. It can be done via NAT1

C. It cannot be done via IGW1 or NAT1

D. It can be done via IGW1 and NAT1

8. They want to allow EC2-18 access to B3. What is your suggestion?

A. Assign R3 to EC2-18. Create an S3 endpoint in VPC3

B. Assign R3 to EC2-18

C. Create an S3 endpoint in VPC3

D. Assign R3 to EC2-18, then create an S3 endpoint in VPC1

9. EC-1 needs to access an external web server via port `888` with minimum exposure to the internet. How can it be done? (Choose two answers.)

A. NACL needs a rule that allows outgoing traffic on port `888`

B. NACL needs rules that allow outgoing traffic on port `888` and incoming traffic on ephemeral ports

C. SG needs a rule that allows outgoing traffic on port `888`

D. SG needs rules that allow outgoing traffic on port `888` and incoming traffic on ephemeral ports

E. SG needs rules that allow outgoing traffic on port `888` and incoming traffic on port `888`

10. Which one of these options is not recommended to protect the data in DynamoDB1?

A. Data encryption

B. SG

C. IAM users/roles

D. VPC endpoint

Answers to the practice questions

1. B
2. A
3. A
4. A
5. A
6. C
7. C
8. A
9. B and C
10. B

Further reading

For further insights into what you've learned about in this chapter, refer to the following links:

- https://docs.aws.amazon.com/security/
- https://aws.amazon.com/iam/
- https://aws.amazon.com/guardduty/
- https://aws.amazon.com/inspector/
- https://aws.amazon.com/config/
- https://aws.amazon.com/premiumsupport/technology/trusted-advisor/
- https://docs.aws.amazon.com/whitepapers/latest/introduction-aws-security/data-encryption.html
- https://docs.aws.amazon.com/whitepapers/latest/introduction-aws-security/security-of-the-aws-infrastructure.html
- https://docs.aws.amazon.com/whitepapers/latest/introduction-aws-security/monitoring-and-logging.html
- https://aws.amazon.com/security/continuous-monitoring-threat-detection/